

Evaluation Framework: Comparing AI-Generated Security Policies

This evaluation compares two versions of a cybersecurity policy for a military organization, both generated using AI tools:

- **Policy 1:** *Benchmark policy*, generated by **ChatGPT (OpenAI)**.
- **Policy 2:** *Test policy*, generated by a **system under evaluation** (e.g., custom RAG pipeline or alternative LLM approach).

The goal is to identify which version performs best in terms of relevance, completeness, compliance, and usability in a real-world military cybersecurity environment.

Note on Evaluation Bias: We acknowledge that using ChatGPT as both the benchmark generator and the evaluator may introduce bias in favor of its own outputs. We are currently exploring ways to mitigate this, including the use of independent reviewers, objective scoring rubrics, and external validation tools.

Comparison Table

Criterion	Policy 1 – Benchmark (ChatGPT)	Policy 2 – System Under Evaluation	Winner
Completeness	Covers lifecycle phases, roles, classifications, NATO links	Very detailed coverage, includes SIEM use, training, escalation plans	Generated
Regulatory & Strategic Alignment	Strong: ISO/IEC 27001, NATO directives, national authorities	Good: Mentions EU/ national guidance, CSIRTs, but lacks NATO alignment	Benchmark
Contextualization	Tailored to military org in Italy, classified comms, formal hierarchy	Clear adaptation to a small, non-IRT military team in Italy	🥷 Tie
Governance & Roles	Clear, concise, chain of command (commander, IRT leader, all personnel)	Strong detail on interim roles and technical specialists	Generated
Clarity and Readability	Simple, directive, clear procedural flow	Slightly denser but well-organized with inline examples and citations	🥷 Tie
Operational Practicality	Covers essentials but assumes basic/manual tools	More realistic for low-resource settings, with SIEM suggestion and fallback roles	Generated

Criterion	Policy 1 – Benchmark (ChatGPT)	Policy 2 – System Under Evaluation	Winner
References and Currency	Uses ISO, NATO CCDCOE, military directives	Cites ENISA-style practical docs and technical compendia	🥷 Tie

Conclusion

Policy 2 (System Under Evaluation) emerged as the **more practical and comprehensive** choice for a small military organization:

- Offers **richer operational details** including SIEM integration, interim response roles, and clear escalation paths.
- Strong in **realistic adaptability** for low-resource military environments (e.g., no established IRT).
- Emphasizes **documentation, training, and continuous improvement**.

Policy 1 (ChatGPT Benchmark), however, demonstrates superior alignment with **formal military standards** (NATO, ISO) and presents a cleaner high-level structure with formal roles and classification levels.

Project Objective

This comparison supports our broader initiative to:

Benchmark AI-generated cybersecurity documents using ChatGPT as a reference, and evaluate alternative systems' ability to deliver context-specific, standards-aligned, and operationally useful content — especially for high-security domains such as the military.